

Cyber Kill Chain Analysis

Brief Attack Summary

The attack followed a sophisticated progression beginning with **Reconnaissance**, where attackers likely identified key billing personnel and technical details about the organization's software environment. This allowed them to proceed to **Weaponization**, crafting a malicious PDF (Invoice_Payment.pdf) embedded with a zero-day exploit (CVE-2024-XXXX) designed to bypass standard defenses.

During the **Delivery** phase, the attackers utilized a targeted phishing email with the subject "Urgent Invoice: Payment Due," spoofing a legitimate sender to deceive the victim. **Exploitation** occurred immediately upon the user opening the attachment, triggering the zero-day vulnerability. This allowed for **Installation**, where the malware established persistence via a registry key modification and downloaded additional payloads.

Once established, the malware entered the **Command and Control (C2)** phase, beaconing out to c2-ecommerce[.]com over encrypted HTTPS to receive further instructions. Finally, in the **Actions on Objectives** phase, attackers moved laterally using Mimikatz to compromise the PAYMENT-SRV01 server, ex filtrated sensitive payment card data to an external domain, and attempted to monetize the breach by leaving a ransom note.

Cyber Kill Chain IOC Mapping

Cyber Kill Chain Phase	Attack Activity Description	Indicators of Compromise (IOCs)
1. Reconnaissance	Gathering info on billing emails and PDF software. <i>(Implied by targeted nature of email)</i>	N/A (Pre-attack phase)
2. Weaponization	Creation of malicious PDF with zero-day exploit.	• File Name: Invoice_Payment.pdf • Exploit: CVE-2024-XXXX • Hash: 7a5d3f1eab7428b65d7c3e457e6c1f3bb6e3ef927d1b98273a4d9b567e81f631
3. Delivery	Phishing email sent to victim.	• Subject: “Urgent Invoice: Payment Due” • Sender: billing@[spoofedcompany].com
4. Exploitation	Execution of code via PDF reader vulnerability.	• Exploit Behavior: Zero-day execution in PDF reader
5. Installation	Malware establishes persistence and downloads tools.	• Registry Key: HKLM\...\Run\UpdaterScript • File Path: C:\Users\[user]\AppData\Local\Temp\Updater.bat
6. Command & Control	Establishing remote communication channel.	• Domain: c2-ecommerce[.]com • IP: 203.0.113.45 • Port: 443 (HTTPS)
7. Actions on Objectives	Lateral movement, data theft, and ransom demand.	• Tool: Mimikatz • Target: PAYMENT-SRV01 • Exfiltration Domain: exfiltration-ecommerce[.]com • Ransom Note: READ_ME.txt (Demand: 5 Bitcoin)